Lab03

#cyber-security

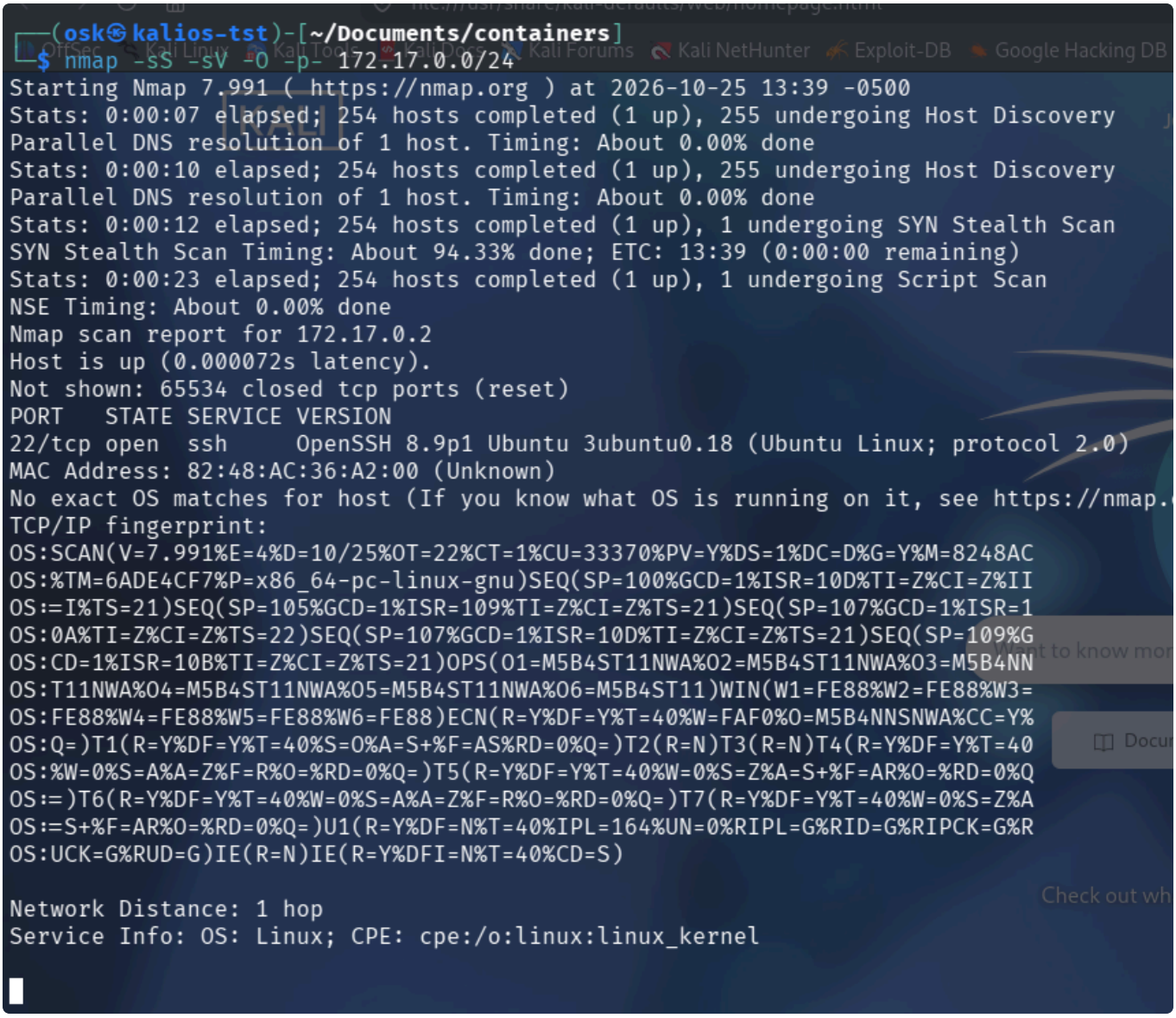
Setup:

After downloading the Dockerfile which specifies the docker image configuration we build the image using the command
`docker build -t dvws .` where:

- -t : is an argument for naming the image that you are buiilding
- . : the directory you provide for the dockerfile configuration, here we supply the current folder we are located in
  We then start the container using `docker run -d -p 2222:22 --name dvws-ssh dvws` where:
- -d : runs the container in a detached mode so the current shell doesn't get stuck
- -p : forwards all traffic on the host on port 2222 to the target on port 22 (default port for the SSH service)
- --name : provide name for the container that we start
- Lastly, provide the name of the image used to run the container

1 - Scanning:

We can scan for the target machine under the Docker IP range (172.17.0.0/24)

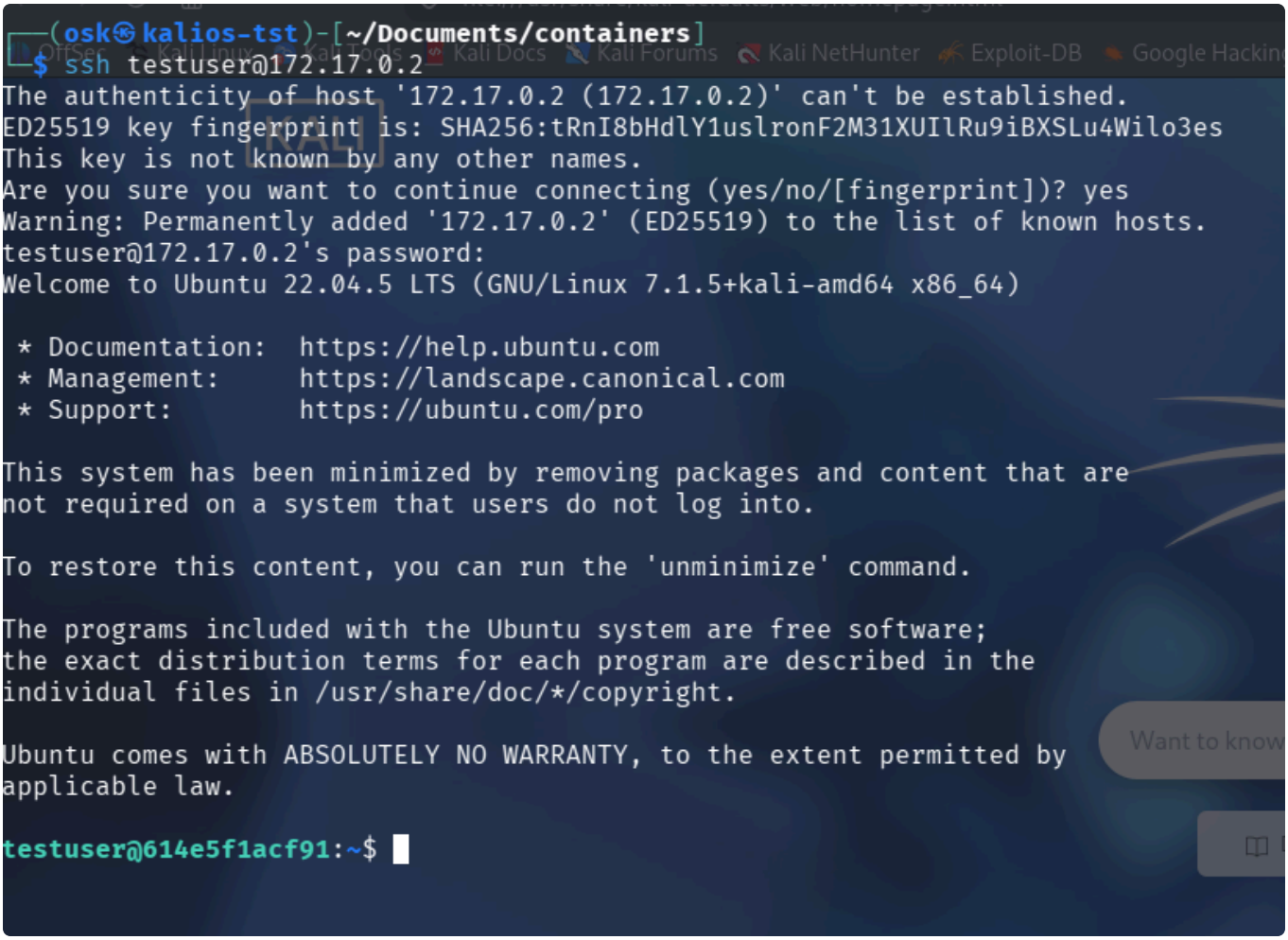


We can see from our scan that a host under the IP address 172.17.0.2 is up, with the ssh service, under the service version OpenSSH 8.9p1 is running with the port 22 open. Nmap was unable to provide an exact OS version match but we can assume it is running on Linux under the Ubuntu, provided under the service section, as well as searching the provided TCP/IP fingerprints to get a better idea.

2 - Verify the SSH Connection:

We can verify the SSH connection by trying to connect via the command `ssh testuser@172.17.0.2`, which upon running will then ask us for credentials (user password), which we enter `test123` and login successfully.

note: These are testing credentials already provided for the exercise.

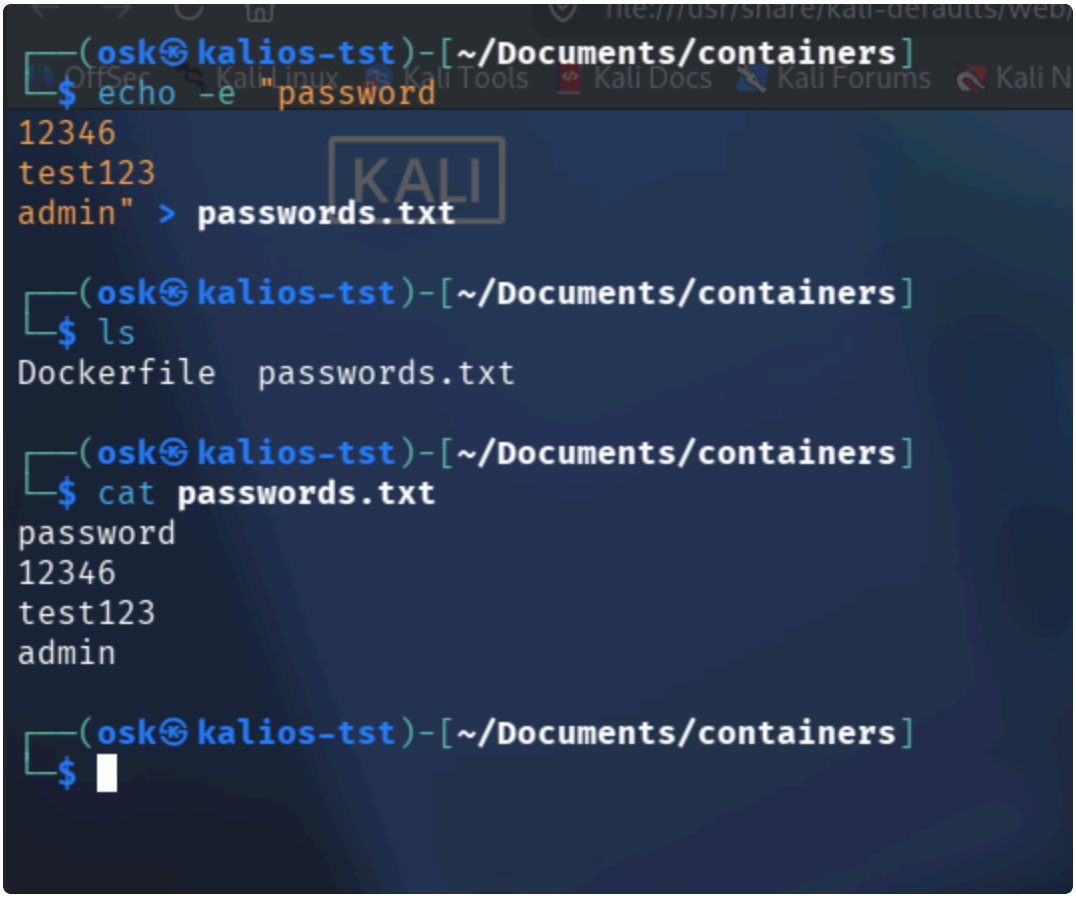


3 - Creating Password Lists:

We create a sample password list file:

```
echo -e "password
123456
test123
admin" > passwords.txt
```

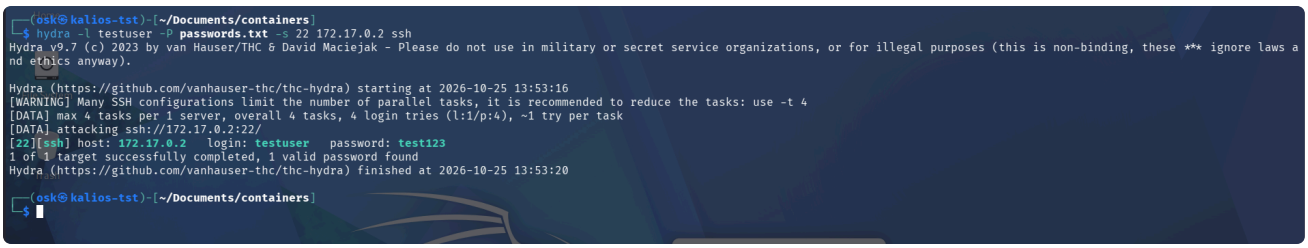
We can then confirm that we've successfully created the password list



4 - Brute Force Using Hydra:

We can try a brute force attack on the login to the SSH service via the following command: `hydra -l testuser -P passwords.txt -s 22 172.17.0.2 ssh` where:

- -l : list the user
- -P : provide the password list
- -s : provide the service port
- Target IP Address
- ssh : target service



We can see that the brute force attack worked with the credentials being username - testuser and password - test123.

Closing Thoughts:

note: It is important to close off ports that are unused as they provide a potential attack vector for threat actors, and ports should only be open if used for a particular purpose and these interfaces should be properly configured in a way that is secure.

- How would you protect the SSH server from brute-force attacks? : Aside from utilizing PKI. Limited login attempts paired with timeouts (consecutive login attempts will have a larger and larger timeout timer until a maximum is reached upon which further login attempts by a target IP will either be blacklisted or the timeout will be significantly longer)
- What additional measures (e.g. limits on the number of logins, use of public-private keys, firewall) would you recommend? : Implementing whitelists where only specific users are able to login
- How does the result change if we use a very strong password? - Becomes significantly harder to guess via brute forcing, make sure the password is around or above the length of 12 characters, includes lowercase, uppercase, special characters and numbers and is ideally randomized as to not be included in any leaked password lists.